API CONTRACT SPECIFICATION

Complete Endpoint Collection & Real-Time Event Schemas

Real-Time Luxury Auction Engine • Base URL: `http://localhost:8080/api/v1`

v2.0.0 Corporate Baseline
Status: Approved Baseline
24 October 2026

Metadata	Value
Document	Complete API Contract Collection & Response Schemas
Project	Real-Time Luxury Auction & Bidding Engine
Version	v2.0.0 (Corporate Baseline)
Status	`Approved Baseline`
Date	24 October 2026
Base URL	`http://localhost:8080/api/v1`

---

1. Global Response Standards

SUCCESS RESPONSE ENVELOPE (HTTP 200 / 201)

```
{
  "status": "success",
  "data": {}
}
```

ERROR RESPONSE ENVELOPE (HTTP 4XX / 5XX)

```
{
  "status": "error",
  "error": {
    "code": "ERROR_CODE_STRING",
    "message": "Descriptive error message in English."
  }
}
```

---

2. Complete Endpoint Specifications

MODULE 1: DUAL-METHOD AUTHENTICATION & RBAC

> **1. `GET /auth/niro/authorize-url`**

The client application invokes this endpoint when a user clicks the *"Login with NIRO"* action. It returns the official NIRO OAuth2 authorization URL alongside a CSRF protection state parameter.

- **Headers:** *None*
- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "redirect_url": "https://auth.niro.internal/oauth2/authorize?client_id=salt_auction_web&response_type=code&redirect_uri=http%3A%2F%2Flocalhost%3A3000%2Fauth%2Fcallback&state=sec_state_981247",
    "state": "sec_state_981247"
  }
}
```

---

2. `POST /auth/login/niro`

After the user authenticates with NIRO and the client receives the callback authorization token, the client exchanges the token via this endpoint.

Backend Account Resolution Logic:

- Validates token against NIRO IdP and extracts user identity (`niro_user_id` , `email` , `username`).
- Inspects the `users` table:
  - **New User:** Automatically registers account (`auth_provider = 'NIRO'` , default role `BIDDER`), provisions an e-wallet (`available_balance = 0.00` , `locked_balance = 0.00`), and issues a JWT session. Returns `is_new_user: true` (HTTP 201).
  - **Existing User:** Authenticates user immediately, loads latest role (`BIDDER` or `ADMIN` if promoted), and issues a JWT session. Returns `is_new_user: false` (HTTP 200).
- **Headers:** `Content-Type: application/json`
- **Request Body:**

```
{
  "niro_token": "eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.niro_sample_token ... "
}
```

- **Response 200 OK (Existing Registered User Authenticated):**

```
{
  "status": "success",
  "data": {
    "is_new_user": false,
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.auction_jwt_token ... ",
    "user": {
      "id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
      "niro_user_id": "NIRO-USR-99812",
      "username": "budi_collector",
      "email": "budi@collector.id",
      "auth_provider": "NIRO",
      "role": "BIDDER"
    },
    "wallet": {
      "available_balance": 150000000.00,
      "locked_balance": 0.00,
      "total_balance": 150000000.00
    }
  }
}
```

- **Response 201 Created (New User Auto-Provisioned):**

```
{
  "status": "success",
  "data": {
    "is_new_user": true,
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.auction_jwt_token ... ",
    "user": {
      "id": "7ca12345-5717-4562-b3fc-2c963f66bbbb",
      "niro_user_id": "NIRO-USR-10293",
      "username": "siti_investor",
      "email": "siti@luxury.com",
      "auth_provider": "NIRO",
      "role": "BIDDER"
    },
    "wallet": {
      "available_balance": 0.00,
      "locked_balance": 0.00,
      "total_balance": 0.00
    }
  }
}
```

- **Response 401 Unauthorized (Invalid or Expired NIRO Token):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_INVALID_NIRO_TOKEN",
    "message": "The provided NIRO authentication token is invalid or expired."
  }
}
```

---

3. `POST /auth/login/email`

Dedicated authentication endpoint strictly reserved for platform Super Admins using email and password (minimum 12 characters). Protected by Redis progressive lockout:

- 1st streak (3 failed attempts): 1-minute lockout (HTTP 429)
- 2nd streak (3 failed attempts): 2-minute lockout (HTTP 429)
- 3rd streak (3 failed attempts): 1-hour lockout (HTTP 429)

- **Headers:** `Content-Type: application/json`
- **Request Body:**

```
{
  "email": "superadmin@salt.id",
  "password": "SuperSecurePassword2026!"
}
```

- **Response 200 OK (Super Admin Authenticated):**

```
{
  "status": "success",
  "data": {
    "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.superadmin_jwt ... ",
    "user": {
      "id": "00000000-0000-0000-0000-000000000001",
      "username": "superadmin_core",
      "email": "superadmin@salt.id",
      "auth_provider": "LOCAL",
      "role": "SUPERADMIN"
    }
  }
}
```

- **Response 400 Bad Request (Password Less Than 12 Characters):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_PASSWORD_TOO_SHORT",
    "message": "Super Admin password must contain a minimum of 12 characters."
  }
}
```

- **Response 403 Forbidden (Non-Super Admin Access Rejection):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_NON_SUPERADMIN_LOGIN",
    "message": "Please use Login with NIRO for your account type."
  }
}
```

- **Response 429 Too Many Requests (Progressive Lockout Triggered):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_ACCOUNT_LOCKED_PROGRESSIVE",
    "message": "Too many consecutive failed login attempts. Account temporarily locked.",
    "retry_after_seconds": 60
  }
}
```

---

4. `GET /admin/users`

Returns the directory of registered platform users with pagination metadata. Restricted to Super Admin.

- **Headers:** `Authorization: Bearer <SUPERADMIN_JWT>`
- **Query Parameters:** `?page=1&limit=10`
- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "items": [
      {
        "id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
        "niro_user_id": "NIRO-USR-99812",
        "username": "budi_collector",
        "email": "budi@collector.id",
        "role": "BIDDER",
        "created_at": "2026-10-24T08:00:00Z"
      }
    ],
    "pagination": {
      "current_page": 1,
      "per_page": 10,
      "total_items": 42,
      "total_pages": 5
    }
  }
}
```


---

5. `PATCH /admin/users/:id/role`

Promotes a registered user from `BIDDER` to `ADMIN` (Auction Manager). The backend increments `token_version:{user_id}` in Redis to instantly revoke active JWT sessions (**Instant Auto-Logout**).

- **Headers:** `Authorization: Bearer <SUPERADMIN_JWT>`, `Content-Type: application/json`
- **Request Body:**

```
{
  "new_role": "ADMIN"
}
```

- **Response 200 OK:**


```
{
  "status": "success",
  "data": {
    "user_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
    "username": "budi_collector",
    "old_role": "BIDDER",
    "new_role": "ADMIN",
    "session_revoked": true,
    "updated_at": "2026-10-24T10:15:00Z"
  }
}
```


- **Response 401 Unauthorized (Client Access with Revoked Session Token):**


```
{
  "status": "error",
  "error": {
    "code": "AUTH_TOKEN_REVOKED",
    "message": "Your user role has been updated. Please log in again to continue."
  }
}
```

MODULE 2: E-WALLET & COLLATERAL MANAGEMENT

6. `GET /wallet/me`

Retrieves liquid available balance and locked collateral balance. Moneter values are serialized as `float64`. Restricted to `BIDDER`.

- **Headers:** `Authorization: Bearer <BIDDER_JWT>`
- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "wallet_id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d",
    "user_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
    "available_balance": 150000000.00,
    "locked_balance": 25000000.00,
    "total_balance": 175000000.00,
    "currency": "IDR"
  }
}
```

---

7. `POST /wallet/topup`

Deposits funds into the bidder's e-wallet (minimum IDR 100,000, whole rupiah multiples). Non-bidder roles are strictly prohibited (HTTP 403).

- **Headers:** `Authorization: Bearer <BIDDER_JWT>`, `Content-Type: application/json`
- **Request Body:**

```
{
  "amount": 50000000.00
}
```

- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "transaction_id": "tx_topup_8871263",
    "entry_type": "WALLET_TOPUP",
    "amount_credited": 50000000.00,
    "new_available_balance": 200000000.00,
    "new_locked_balance": 25000000.00,
    "new_total_balance": 225000000.00,
    "created_at": "2026-10-24T10:30:00Z"
  }
}
```

- **Response 400 Bad Request (Amount Below Minimum Threshold):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_TOPUP_AMOUNT_TOO_LOW",
    "message": "Minimum top-up amount is IDR 100,000 in whole rupiah multiples."
  }
}
```

- **Response 403 Forbidden (Non-Bidder Access Attempt):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_TOPUP_RESTRICTED",
    "message": "Wallet top-up is exclusive to Bidder accounts."
  }
}
```

MODULE 3: MARKETPLACE & PRODUCT CATALOG

8. `GET /auctions/active`

Retrieves catalog snapshot of active luxury items with pagination metadata. Product images are served as compressed Base64 strings decoded from database `BYTEA` BLOBs.

- **Query Parameters:** `?page=1&limit=10&category=LUXURY_WATCHES`
- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "items": [
      {
        "id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
        "title": "Rolex Submariner Date 126610LN Oystersteel",
        "category": "LUXURY_WATCHES",
        "condition_grade": "PRISTINE_MINT",
        "authenticity_guarantee": "Full Set 2023, Box & Papers",
        "image_base64_compressed": " ... ",
        "model_type": "CAPPED",
        "status": "ACTIVE",
        "min_price": 200000000.00,
        "current_price": 350000000.00,
        "max_price": 500000000.00,
        "start_time": "2026-10-24T00:00:00Z",
        "end_time": "2026-10-25T12:00:00Z",
        "total_bids": 18
      }
    ],
    "pagination": {
      "current_page": 1,
      "per_page": 10,
      "total_items": 1,
      "total_pages": 1
    }
  }
}
```

---

9. `GET /auctions/:id`

Retrieves granular specifications, certificate details, allowed discrete increment buttons array, and real-time room status.

- **Path Parameters:** `:id` (UUID)
- **Response 200 OK:**


```
{
  "status": "success",
  "data": {
    "id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
    "title": "Rolex Submariner Date 126610LN Oystersteel",
    "category": "LUXURY_WATCHES",
    "condition_grade": "PRISTINE_MINT",
    "authenticity_guarantee": "Full Set 2023, Certified Official Escrow",
    "description": "Black cerachrom ceramic bezel, 41mm case, complete box & papers.",
    "image_base64_compressed": " ... ",
    "model_type": "CAPPED",
    "status": "ACTIVE",
    "min_price": 200000000.00,
    "current_price": 350000000.00,
    "allowed_increment_steps": [
      5000000.00,
      10000000.00,
      20000000.00
    ],
    "max_price": 500000000.00,
    "highest_bidder_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
    "highest_bidder_masked": "Bu**or",
    "start_time": "2026-10-24T00:00:00Z",
    "end_time": "2026-10-25T12:00:00Z",
    "anti_sniping_extension_minutes": 2,
    "total_bids": 18
  }
}
```

MODULE 4: REAL-TIME BIDDING CORE ENGINE

10. `POST /auctions/:id/bids`

Submits an incremental bid via pre-configured discrete increment buttons. Free-text amount entry is prohibited. Executes atomic Redis Lua script (`bid_placement.lua` < 5 ms):

- Moves funds from `available_balance` to `locked_balance`.
- Retains previous bidders' funds in `locked_balance` during active auction.
- If bid hits ceiling in Capped auction $\rightarrow$ instant **Buy-Out** (`CLOSED_AWARDED`).
- If bid arrives in last 2 minutes and velocity $\ge$ 10 hits/s $\rightarrow$ triggers **Anti-Sniping Extension**.

- **Headers:** `Authorization: Bearer <BIDDER_JWT>` , `Content-Type: application/json`
- **Request Body:**

```
{
  "step_increment": 10000000.00
}
```

- **Response 200 OK (Bid Accepted):**

```
{
  "status": "success",
  "data": {
    "bid_status": "ACCEPTED",
    "lot_id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
    "new_price": 360000000.00,
    "highest_bidder_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
    "wallet_available_remaining": 140000000.00,
    "wallet_collateral_locked": 35000000.00,
    "anti_sniping_extended": false,
    "new_end_time": "2026-10-25T12:00:00Z",
    "created_at": "2026-10-24T11:00:00Z"
  }
}
```

- **Response 400 Bad Request (Invalid Increment Step):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_INVALID_INCREMENT_STEP",
    "message": "Bid must match one of the allowed discrete increment steps [5000000, 10000000, 20000000]."
  }
}
```

- **Response 400 Bad Request (Insufficient Liquid Balance):**

```
{
  "status": "error",
  "error": {
    "code": "ERR_INSUFFICIENT_AVAILABLE_BALANCE",
    "message": "Your available balance is insufficient to place this bid."
  }
}
```

MODULE 5: AUTONOMOUS PROXY BIDDING

11. `POST /auctions/:id/proxy-bid`

Configures an autonomous proxy bot to place counter-bids automatically up to a maximum limit (`max_limit`).

- **Headers:** `Authorization: Bearer <BIDDER_JWT>` , `Content-Type: application/json`
- **Request Body:**

```
{
  "max_limit": 450000000.00
}
```

- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "proxy_rule_id": "prx_9901827",
    "lot_id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
    "user_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
    "max_limit": 450000000.00,
    "proxy_status": "ACTIVE",
    "configured_at": "2026-10-24T11:15:00Z"
  }
}
```

---

12. `DELETE /auctions/:id/proxy-bid`

Deactivates autonomous proxy bidding on the specified lot.

- **Headers:** `Authorization: Bearer <BIDDER_JWT>`
- **Response 200 OK:**

```
{
  "status": "success",
  "data": {
    "lot_id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
    "proxy_status": "CANCELLED",
    "deactivated_at": "2026-10-24T11:20:00Z"
  }
}
```

MODULE 6: ADMIN LOT CURATION & MANAGEMENT

13. `POST /admin/auctions`

Auction Manager creates a new luxury auction listing. The binary image file is received via `multipart/form-data` and directly persisted into PostgreSQL as a `BYTEA` **BLOB** without third-party storage dependencies.

- **Headers:** `Authorization: Bearer <ADMIN_JWT>`, `Content-Type: multipart/form-data`
- **Form-Data Fields:**
  - `title` (text): `"Hermes Birkin 25 Togo Gold Hardware"`
  - `category` (text): `"DESIGNER_BAGS"`
  - `condition_grade` (text): `"MINT"`
  - `authenticity_guarantee` (text): `"Store Receipt 2024, Original Orange Box, Dustbag, CITES cert"`
  - `description` (text): `"Store fresh condition, highly sought-after collector investment piece."`
  - `image` (binary file): `[Binary image payload JPEG/PNG/WEBP]`
  - `min_price` (number): `250000000.00`
  - `allowed_increment_steps` (json string): `"[5000000, 10000000, 20000000]"`
  - `max_price` (number, optional): `400000000.00`
  - `window_duration_seconds` (number): `86400`
  - `anti_sniping_extension_minutes` (number, optional): `2`
- **Response 201 Created:**

```
{
  "status": "success",
  "data": {
    "id": "c1f76d22-192a-4c28-8742-1928374aef12",
    "title": "Hermes Birkin 25 Togo Gold Hardware",
    "category": "DESIGNER_BAGS",
    "condition_grade": "MINT",
    "authenticity_guarantee": "Store Receipt 2024, Original Orange Box, Dustbag, CITES cert",
    "image_base64_compressed": " ... ",
    "model_type": "CAPPED",
    "status": "ACTIVE",
    "min_price": 250000000.00,
    "current_price": 250000000.00,
    "max_price": 400000000.00,
    "start_time": "2026-10-24T12:00:00Z",
    "end_time": "2026-10-25T12:00:00Z",
    "anti_sniping_extension_minutes": 2,
    "created_by": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
    "created_at": "2026-10-24T12:00:00Z"
  }
}
```


- **Response 400 Bad Request (Invalid Auction Parameters):**


```
{
  "status": "error",
  "error": {
    "code": "ERR_INVALID_AUCTION_PARAMS",
    "message": "Maximum price must be strictly greater than minimum price, and product image file is requir
ed."
  }
}
```


---

3. Real-Time Streaming Specification: Server-Sent Events (SSE)

The platform strictly utilizes **Server-Sent Events (SSE)** over persistent HTTP/2 (`text/event-stream`), providing firewall-friendly unidirectional server-to-client streaming with low latency (< 300 ms).

- **Room Lot Stream Endpoint:** `GET /api/v1/sse/auctions/:id`
- **Global Catalog Stream Endpoint:** `GET /api/v1/sse/catalog`
- **Server Headers:**
  - `Content-Type: text/event-stream`
  - `Cache-Control: no-cache`
  - `Connection: keep-alive`
  - `X-Accel-Buffering: no`
- **Heartbeat Ping:** Server sends comment `: ping\n\n` every 15 seconds.
- **Auto-Reconnect:** Web client reconnects automatically via native browser `EventSource` with `Last-Event-ID` header.

3.1 OUTBOUND SSE BROADCAST EVENT FRAMES

1. Event `PRICE_UPDATED` (New Valid Bid Committed)

```
event: PRICE_UPDATED
id: 1729782400123
data: {
  "lot_id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
  "current_price": 360000000.00,
  "highest_bidder_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
  "highest_bidder_masked": "Bu**or",
  "increment_added": 10000000.00,
  "total_bids_count": 28
}
```

2. Event `TIME_EXTENDED` (Velocity Anti-Sniping Triggered)

```
event: TIME_EXTENDED
id: 1729782415456
data: {
  "lot_id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
  "extension_minutes": 2,
  "new_end_time": "2026-10-25T12:02:00.000Z",
  "reason": "ANTI_SNIPING_TRIGGERED"
}
```

3. Event `AUCTION_BUYOUT_CLOSED` (Valuation Ceiling Reached)

```
event: AUCTION_BUYOUT_CLOSED
id: 1729782420789
data: {
  "lot_id": "e0b9b3e1-872b-42e7-91a6-f7615cb38421",
  "winner_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
  "winner_masked": "Bu**or",
  "buyout_price": 500000000.00,
  "closed_reason": "VALUATION_CEILING_REACHED"
}
```

4. Event `AUCTION_CONCLUDED` (Window Expired & Settlement Finished)

```
event: AUCTION_CONCLUDED
id: 1729782490000
data: {
  "lot_id": "c1f76d22-192a-4c28-8742-1928374aef12",
  "status": "SETTLED",
  "winner_id": "8bb30e92-3a52-47d1-ba76-218f2d5f22e1",
  "winner_masked": "An**or",
  "final_price": 310000000.00,
  "collateral_unfrozen_for_others": true
}
```

5. Event `NEW_LOT_PUBLISHED` (New Lot Active in Catalog)

```
event: NEW_LOT_PUBLISHED
id: 1729782500000
data: {
  "lot_id": "c1f76d22-192a-4c28-8742-1928374aef12",
  "title": "Hermes Birkin 25 Togo Gold Hardware",
  "category": "DESIGNER_BAGS",
  "starting_price": 250000000.00,
  "model_type": "CAPPED",
  "end_time": "2026-10-25T12:30:00.000Z"
}
```

---

4. Executive Document Sign-Off

This API Contract Specification (*API Contract Collection & Real-Time Event Schemas*) has been formally verified, reviewed, and approved as the binding architectural interface contract governing Backend Services, Next.js Frontend Web Applications, and System Integrators.

PROJECT MANAGER **Geri Setyo Andrian**	TECH LEAD / TECHNICAL ARCHITECT **Alini**	SYSTEM ANALYST / SOLUTION ARCHITECT **Daniel H. S.**
		
Date: 2026-10-24 **Status:** [✓] Approved [ ] Revision	**Date:** 2026-10-24 **Status:** [✓] Approved [ ] Revision	**Date:** 2026-10-24 **Status:** [✓] Approved [ ] Revision